



《系统软件原理与设计III-数据库系统》

第9章 数据库安全

计算机科学与工程学院（网络空间安全学院）

任课教师：胡旺

2025年12月16日星期二



本章内容



1

计算机安全概述

2

数据库安全性控制

3

自主访问控制 (DAC)

4

强制访问控制 (MAC)

5

跟踪审计

6

*数据库安全性的其他技术



- 数据库的一大特点：**数据共享**，但数据共享必然带来数据库的安全性问题；
- 数据库系统中的数据共享是在DBMS统一的严格的控制之下的共享，即**只允许有合法使用权限的用户访问允许他存取的数据**；
- 数据库系统的安全保护措施是否有效是数据库系统主要的性能指标之一；
- 数据库的安全性和计算机系统的安全是紧密联系、互相支持的；



■ 什么是数据库的安全性？

- ◆ 保护数据库，防止因用户非法使用数据库造成数据泄露、更改或破坏。

■ 什么是数据的保密？

- ◆ 数据保密是指用户合法地访问到机密数据后能否对这些数据保证不泄密。
- ◆ 通过制订法律道德准则和政策法规来保证。



■ 计算机安全性

- ◆ 保护计算机系统硬件、软件及数据，防止其因偶然或恶意的原因使系统遭到破坏，数据遭到更改或泄露等。
- ◆ 立体防御：**进不来、看不见、搞不掉、跑不了**

■ 三类安全性问题

- ◆ 技术安全类
- ◆ 管理安全类
- ◆ 政策法律类



■ 可信计算机系统评测标准

■ TCSEC（桔皮书）

- ◆ 1985年美国国防部（DoD）正式颁布《DoD可信计算机系统评估标准》，简称TCSEC或DoD85。

■ TDI（紫皮书）

- ◆ 1991年4月美国NCSC（国家计算机安全中心）颁布了《可信计算机系统评估标准关于可信数据库系统的解释》，简称TDI。
- ◆ 将TCSEC扩展到数据库管理系统。定义了数据库管理系统的设计与实现中需满足和用以进行安全性级别评估的标准。



■ TCSEC/TDI 安全级别划分

- ◆ 四组七个等级。
- ◆ 按系统可靠或可信程度逐渐增高。
- ◆ 各安全级别之间具有一种偏序向下兼容的关系。

安全级别	定义
A1	验证设计 (Verified Design)
B3	安全域 (Security Domains)
B2	结构化保护 (Structural Protection)
B1	标记安全保护 (Labeled Security Protection)
C2	受控的存取保护 (Controlled Access Protection)
C1	自主安全保护 (Discretionary Security Protection)
D	最小保护 (Minimal Protection)



■ D级

- ◆ 将一切不符合更高标准的系统均归于D组
- ◆ 典型例子：DOS是安全标准为D的操作系统，DOS在安全性方面几乎没有什么专门的机制来保障

■ C1级

- ◆ 非常初级的自主安全保护，能够实现对用户和数据的分离，进行自主存取控制（DAC），保护或限制用户权限的传播。

■ C2级

- ◆ 安全产品的最低档次；
- ◆ 提供受控的存取保护，将C1级的DAC进一步细化，以个人身份注册负责，并实施审计和资源隔离；
- ◆ 达到C2级的产品在其名称中往往不突出“安全”（Security）这一特色。
- ◆ 典型例子
 - 操作系统：Microsoft的Windows NT 3.5
 - 数据库：Oracle公司的Oracle 7，Sybase公司的 SQL Server 11.0.6



■ B1级

- ◆ 标记安全保护。“安全” (Security) 或 “可信的” (Trusted) 产品。
- ◆ 对系统的数据加以标记，对标记的主体和客体实施强制存取控制 (MAC)、审计等安全机制。
- ◆ 典型例子
 - 操作系统：数字设备公司的SEVMS VAX Version 6.0，HP-UX BLS release 9.0.9+
 - 数据库：Oracle公司的Trusted Oracle 7，Sybase公司的Secure SQL Server version 11.0.6，Informix公司的Incorporated INFORMIX-OnLine / Secure 5.0

■ B2级

- ◆ 结构化保护
- ◆ 建立形式化的安全策略模型并对系统内的所有主体和客体实施DAC和MAC。
- ◆ 经过认证的B2级以上的安全系统非常稀少
- ◆ 典型例子
 - 操作系统：Trusted Information Systems公司的Trusted XENIX一种产品
 - 网络产品：Cryptek Secure Communications公司的LLC VSLAN一种产品
 - 数据库：没有符合B2标准的产品



■ B3级

- ◆安全域
- ◆该级的TCB必须满足访问监控器的要求，审计跟踪能力更强，并提供系统恢复过程。

■ A1级

- ◆验证设计：即提供B3级保护的同时给出系统的形式化设计说明和验证以确信各安全保护真正实现

■ 说明：B2以上的系统

- ◆还处于理论研究阶段；
- ◆应用多限于一些特殊的部门如军队等；
- ◆美国正在大力发展安全产品，试图将目前仅限于少数领域应用的B2安全级别下放到商业应用中来，并逐步成为新的商业标准。



本章内容



1

计算机安全概述



2

数据库安全性控制

3

自主访问控制 (DAC)

4

强制访问控制 (MAC)

5

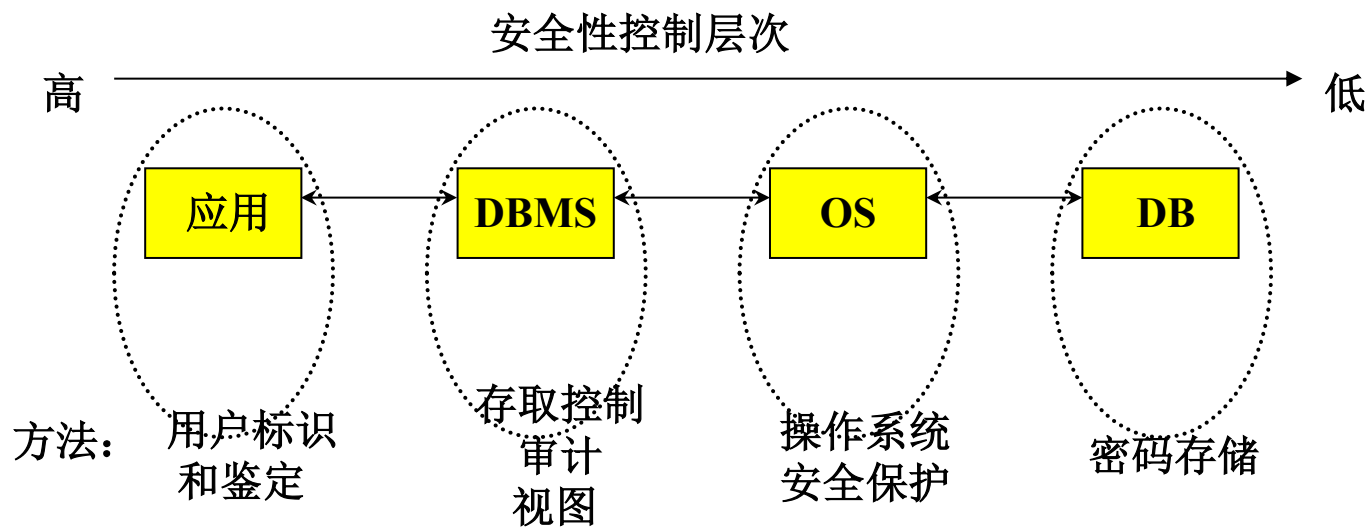
跟踪审计

6

*数据库安全性的其他技术



- ◆物理位置
- ◆人员
- ◆操作系统
- ◆网络
- ◆数据库系统





本章内容



1

计算机安全概述

2

数据库安全性控制



3

自主访问控制 (DAC)

4

强制访问控制 (MAC)

5

跟踪审计

6

*数据库安全性的其他技术



■ 自主访问控制（DAC）

- ◆ 对用户访问数据库中各种资源（包括表、视图、程序等）的权利（包括创建、查询、更新、执行等）的控制；
- ◆ C2级， 灵活
- ◆ 权限是指允许某个用户以某种方式访问一些数据对象；
- ◆ 同一用户对于不同的数据对象有不同的存取权限，不同的用户对同一对象也有不同的权限，用户还可将其拥有的存取权限转授给其他用户。



■ 具有CONNECT特权的用户

- ◆ 可以与数据库连接，能根据授权进行数据库中数据的查询、更新，能创建视图。

■ 具有RESOURCE特权的用户

- ◆ 除具有CONNECT特权外，还能创建表、索引，修改表结构，能将自己创建的数据对象的访问权授予其他用户或从其他用户那儿收回，对自己创建的数据对象能进行跟踪审查。

■ 具有DBA特权的用户

- ◆ 能进行所有的数据库操作。



■ 访问数据的权限：

- ◆ SELECT（读取权限）：允许读数据，但不能修改数据。
- ◆ INSERT（插入权限）：允许插入一条新的数据，但不能修改已有数据。
- ◆ UPDATE（修改权限）：允许修改数据，但不能删除数据。
- ◆ DELETE（删除权限）：允许删除数据。

■ 修改数据库模式（SQL92标准）的权限：

- ◆ Index（索引权限）：允许建立或删除索引。
- ◆ Create（创建权限）：允许建立新的关系表。
- ◆ Alter（修改权限）：允许对关系表中的属性进行增加、删除。
- ◆ Drop（删除权限）：允许删除关系表。



■ 其它权限

- ◆ **REFERENCE权限**：允许用户在建立关系的完整性约束中引用一个参照关系
- ◆ **USAGE权限**：授权用户使用一个指定的域
- ◆ **TRIGGER权限**：授权用户定义关系表中触发器的权利
- ◆ **EXECUTE权限**：授予用户执行一个函数或过程的权利
- ◆ **UNDER权限**：授权用户建立一给定类的子类



■ 权限示例

```
INSERT INTO RecipeDetail (Mno)
SELECT Mno FROM Medicinee
WHERE Mname LIKE '%替硝唑%'
```

- ◆ 需要一个RecipeDetail 表上的INSERT权限，该权限可以仅仅是RecipeDetail表上的INSERT (Mno) 权限
- ◆ 需要一个对Medicine关系表的SELECT授权，这个授权也可以只针对Medicine中的Mno、Mname、Mprice属性



- 授权就是赋予用户一定的操作数据对象的权利。
- 授权可以由DBA授予，也可以由数据对象的创建者授予
- 授权格式：

```
GRANT {all privileges|privilege{. privilege...}}  
ON [TABLE] tablename|viewname  
TO [PUBLIC|user_name{, user_name...}]  
[WITH GRANT OPTION]
```

- ◆ ALL PRIVILEGES是所有权限的总称
- ◆ 数据对象可以是基本表，也可以是视图
- ◆ 用户名可以代表单一用户也可以代表一组用户，当代表一组用户时称为角色。PUBLIC是所有数据库用户的总称；
- ◆ WITH GRANT OPTION，受权者可以将此权限转授给其他用户；
- ◆ 一个用户如果是表的创建者，他就自动拥有了对所创建表的所有权利以及将该表权利授予其他用户的权利，而且不能取消。



■ **授权示例：** 假定用户WangPing创建了表RecipeDetail, Medicine, RecipeMaster, 并且WangPing执行如下授权命令。

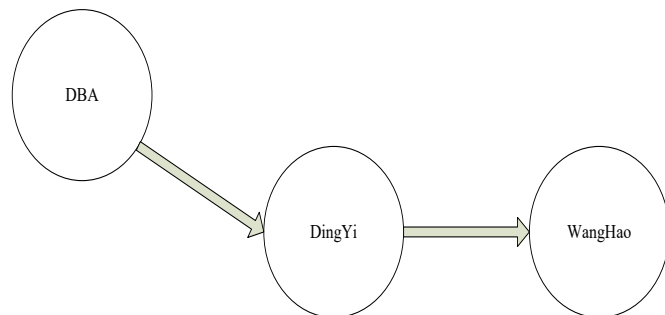
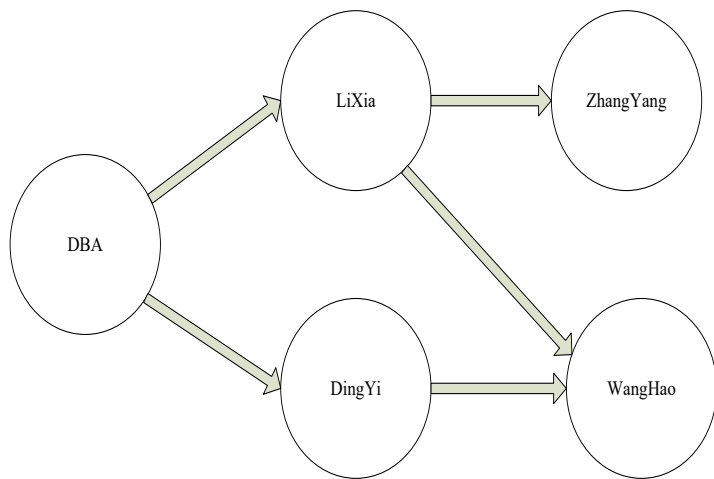
- ◆ GRANT SELECT ON RecipeDetail TO LiXia;
- ◆ GRANT SELECT ON RecipeMaster TO LiXia WITH GRANT OPTION;
- ◆ GRANT UPDATE (Mprice) ON Medicine TO WangHao;
- ◆ GRANT REFERENCE (Mno) ON Medicine TO ZhangYang;
- ◆ GRANT INSERT, DELETE ON RecipeDetail TO MengFan WITH GRANT OPTION;
- ◆ LiXia能够对RecipeDetail和RecipeMaster执行查询语句, 并能将RecipeMaster的查询权限授予DengTian:
 - GRANT SELECT ON RecipeMaster TO DengTian;
- ◆ WangHao只能修改Medicine表中的Mprice列的值。
- ◆ 下列两个语句WangHao能否执行?
 - UPDATE Medicine SET Mprice=70;
 - UPDATE Medicine SET Mprice=Mprice-10;



■ 授权图

- ◆ 用授权图来表示授权在用户之间的传递
- ◆ 图中的结点表示用户，如果用户 U_i 将权限传递给了 U_j ，则在图中增加一条边 $U_i \rightarrow U_j$ 。图的根是DBA
- ◆ 用户具有授权当且仅当存在从授权图的根到代表该用户的结点的路径
- ◆ 示例

- GRANT SELECT ON RecipeDetail TO LiXia WITH GRANT OPTION; (由DBA 执行)
- GRANT SELECT ON RecipeDetail TO ZhangYang WITH GRANT OPTION; (由LiXia 执行)
- GRANT SELECT ON RecipeDetail TO DingYi WITH GRANT OPTION; (由DBA 执行)
- GRANT SELECT ON RecipeDetail TO WangHao WITH GRANT OPTION; (由LiXia 执行)
- GRANT SELECT ON RecipeDetail TO WangHao WITH GRANT OPTION; (由DingYi 执行)
- 假设DBA决定收回对用户LiXia的授权: **REVOKE SELECT ON RecipeDetail FROM LiXia CASCADE;**





■ 视图授权

- ◆ 对视图也应可以授权。
- ◆ 要授予其他用户与访问视图相关的权利，授权者必须拥有该视图（而且在视图所引用基本表或视图上有必要的权限）或已经通过WITH GRANT OPTION被授予了这些权限。
- ◆ 若要在一个视图上授予插入、删除或更新权限，视图必须是可更新的。
- ◆ 用户要建立视图，首先必须要有对所引用基本表或视图的SELECT权利。



- **视图授权示例：** 假定医院的一位员工Jian希望能看到患者到科室看病的信息，但他不具有查阅医生处方的权限，即他没有对RecipeMaster表的授权。

(1) CREATE VIEW Recipe-Doctor AS

(SELECT Pname, Ddeptno

FROM RecipeMaster, patient, doctor

WHERE patient.Pno= RecipeMaster.Pno AND
RecipeMaster.Dno=doctor.Dno);

(2) GRANT SELECT ON Recipe-Doctor TO Jian;

(3) Jian可以执行如下查询语句：

SELECT * FROM Recipe-Doctor

- ◆ 表的所有者创建视图要成功，首先必须要拥有对处方表RecipeMaster的SELECT权限，否则，视图的创建请求将被拒绝。
- ◆ 若视图创建者的SELECT权限被回收，则视图被删除。若视图创建者获得了新的基本表的权限，则他对所创建的视图自动获得新的权限



■ 视图子集授权

```
CREATE VIEW Med-lower AS
```

```
SELECT * FROM Medicine WHERE Mprice<45;
```

```
GRANT SELECT ON Med-lower TO Jian;
```



■ 创建角色

◆ `CREATE ROLE Admin;`

■ 对角色授权：同用户授权一样

◆ `GRANT SELECT ON RecipeMaster TO Admin;`



■ 创建用户（SQL Server）

◆ 创建用户：CREATE USER username FOR LOGIN login_name;

● 例：CREATE USER alex FOR LOGIN alex;

◆ 创建登录名：CREATE LOGIN alex WITH PASSWORD='Uvxs245! ';

■ 用户加入角色

◆ ALTER ROLE role_name ADD user_name;



■ 收回权限格式

```
REVOKE [WITH GRANT OPTION FOR] {ALL PRIVILEGES|privilege {  
    Privilege...}}  
ON [TABLE] tablename|viewname  
FROM [PUBLIC|user_name {, user_name...}]  
[RESTRICT|CASCADE]
```

■ 示例：若WangPing在授权后，发现用户的权限分配不恰当，就可以执行如下命令收回部分用户的操作权限：

- ◆ REVOKE SELECT ON RecipeDetail FROM LiXia;
- ◆ REVOKE UPDATE (Mprice) ON Medicine FROM WangHao;
- ◆ REVOKE GRANT OPTION FOR SELECT ON RecipeMaster FROM LiXia;

■ RESTRICT与CASCADE

- ◆ 从一个用户那里收回权限可能导致其他用户也失去该权限。这一行为称为级联回收CASCADE。在大多数数据库系统中，级联回收是默认行为。
- ◆ 可以指定RESTRICT方式：REVOKE SELECT ON RecipeMaster FROM LiXia RESTRICT;



■ 授权粒度：指可以定义的数据对象的范围

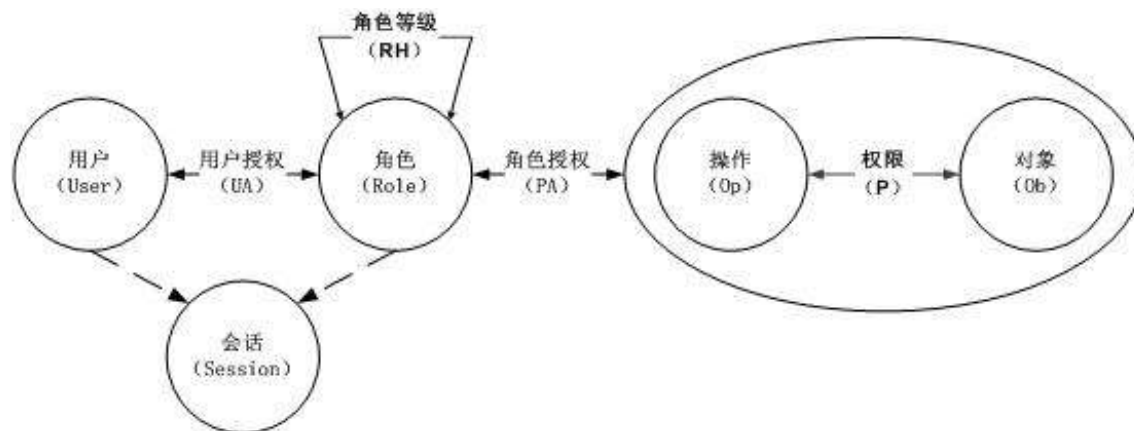
- ◆它是衡量授权机制是否灵活的一个重要指标
- ◆授权定义中数据对象的粒度越细，即可以定义的数据对象的范围越小，授权子系统就越灵活，但系统定义与检查权限的开销会相应增大
- ◆能否提供与数据值有关的授权反映了授权子系统精巧程度

■ 关系数据库中授权的数据对象粒度

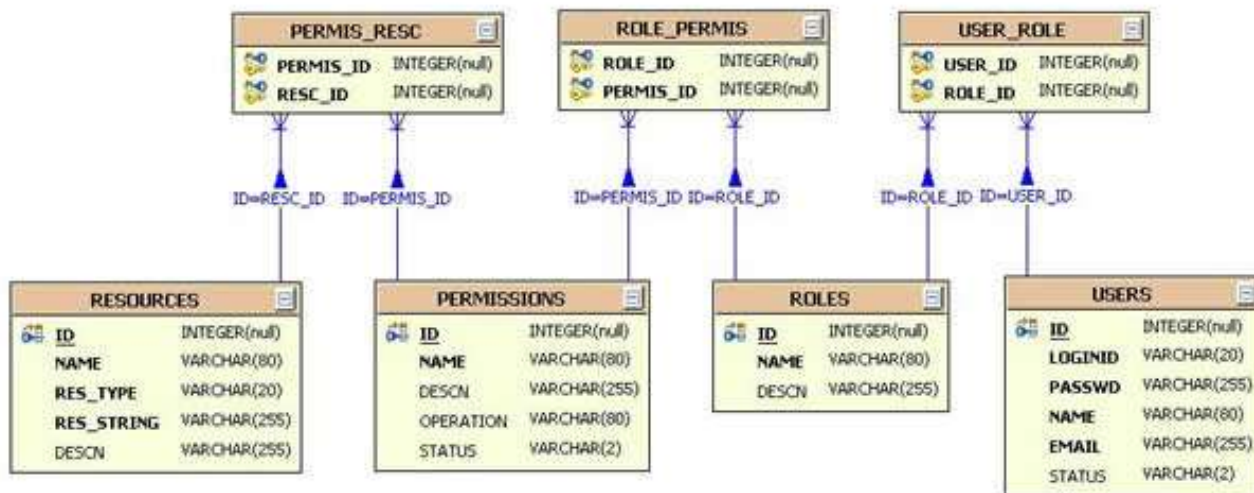
- ◆数据库
- ◆表
- ◆属性列
- ◆行



RBAC示意图



RBAC实现





本章内容



1

计算机安全概述

2

数据库安全性控制

3

自主访问控制 (DAC)



4

强制访问控制 (MAC)

5

跟踪审计

6

*数据库安全性的其他技术



■ 强制访问控制（MAC）的特征

- ◆ 对所有主体（系统中的活动实体，如用户）及其所控制的客体（如进程、文件、基表、视图等）实施强制访问控制
- ◆ B1级，严格
- ◆ 每一个数据对象被标以一定的密级，每一个用户也被授予某一个级别的许可证，对于任意一个对象，只有具有合法许可证的用户才可以存取

■ 在MAC中，DBMS所管理的全部实体被分为主体和客体两大类

- ◆ 主体是系统中的活动实体
 - DBMS所管理的实际用户
 - 代表用户的各进程
- ◆ 客体是系统中的被动实体，是受主体操纵的
 - 文件，基表，索引，视图



■ 敏感度标记（Label）

- ◆ 对于主体和客体，DBMS为它们每个实例（值）指派一个敏感度标记；
- ◆ 敏感度标记级别：绝密，机密，可信，公开；
- ◆ 主体的敏感度标记称为许可证级别，客体的敏感度标记称为密级；
- ◆ MAC机制就是通过对比主体的Label和客体的Label，最终确定主体是否能够存取客体。

■ 强制存取控制规则

- ◆ 仅当主体的许可证级别大于或等于客体的密级时，该主体才能读取相应的客体。
- ◆ 仅当主体的许可证级别小于或等于客体的密级时，该主体才能写相应的客体。



■ MAC示例：

- ◆ 假定系统设置有4个等级：top secret (TS), secret (S), confidential (C), unclassified (U)。
- ◆ 若用户LiXia和WangHao的许可证级别分别是C和S，则用户LiXia看不到表中的任何记录，而WangHao可以看到其中的一条记录。

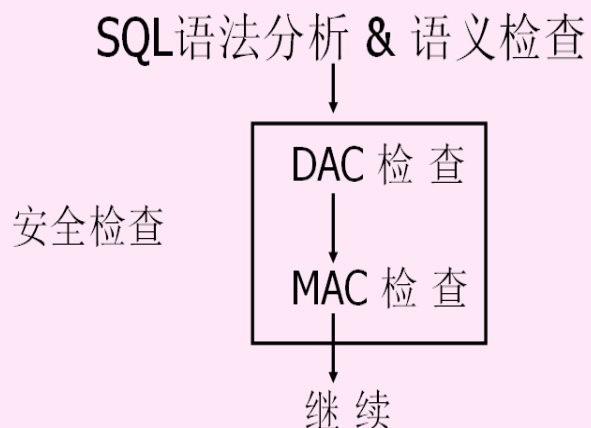
Rno	Pno	Dno	Pgno	Rdatetime	Security class
1282317	481	140	1645	2007-07-21 13:12:01	S
1282872	201	21	2170	2007-07-22 10:10:03	TS



■ MAC与DAC

- ◆ DAC与MAC共同构成DBMS的安全机制
- ◆ 先进行DAC检查，通过DAC检查的数据对象再由系统进行MAC检查
- ◆ 只有通过MAC检查的数据对象方可存取。

DAC + MAC安全检查示意图





本章内容



1

计算机安全概述

2

数据库安全性控制

3

自主访问控制 (DAC)

4

强制访问控制 (MAC)



5

跟踪审计

6

*数据库安全性的其他技术



■ 审计: Audit

- ◆ 启用一个专用的审计日志 (Audit Log), 将用户对数据库的所有操作记录在上面;
- ◆ DBA可以利用审计日志中的追踪信息, 找出非法存取数据的人;
- ◆ C2以上安全级别的DBMS必须具有审计功能。

■ 审计功能的可选性

- ◆ 审计很费时间和空间;
- ◆ DBA可以根据应用对安全性的要求, 灵活地打开或关闭审计功能。
- ◆ SET AUDIT ON/OFF



本章内容



1

计算机安全概述

2

数据库安全性控制

3

自主访问控制 (DAC)

4

强制访问控制 (MAC)

5

跟踪审计



6

*数据库安全性的其他技术



■ 数据加密

- ◆ 防止数据库中数据在存储和传输中失密的有效手段
- ◆ 加密的基本思想：根据一定的算法将原始数据（术语为明文，Plain text）变换为不可直接识别的格式（术语为密文，Cipher text）
- ◆ 替换方法：使用密钥（Encryption Key）将明文中的每一个字符转换为密文中的一个字符
- ◆ 置换方法：将明文的字符按不同的顺序重新排列
- ◆ 混合方法：美国1977年制定的官方加密标准：数据加密标准（Data Encryption Standard，简称DES）

■ DBMS中的数据加密

- ◆ 有些数据库产品提供了数据加密例行程序；而有些数据库产品本身未提供加密程序，但提供了接口
- ◆ 数据加密功能通常也作为可选特征，允许用户自由选择
 - 数据加密与解密是比较费时的操作
 - 数据加密与解密程序会占用大量系统资源
 - 应该只对高度机密的数据加密



■ 鉴定

- ◆ 询问-应答系统
- ◆ 只有用户具有的物品鉴别
- ◆ 用户个人特征鉴别
- ◆ 数字签名
- ◆ 认证技术



本章小结



■ DAC

◆ USER & ROLE

◆ GRANT

◆ REVOKE

■ MAC